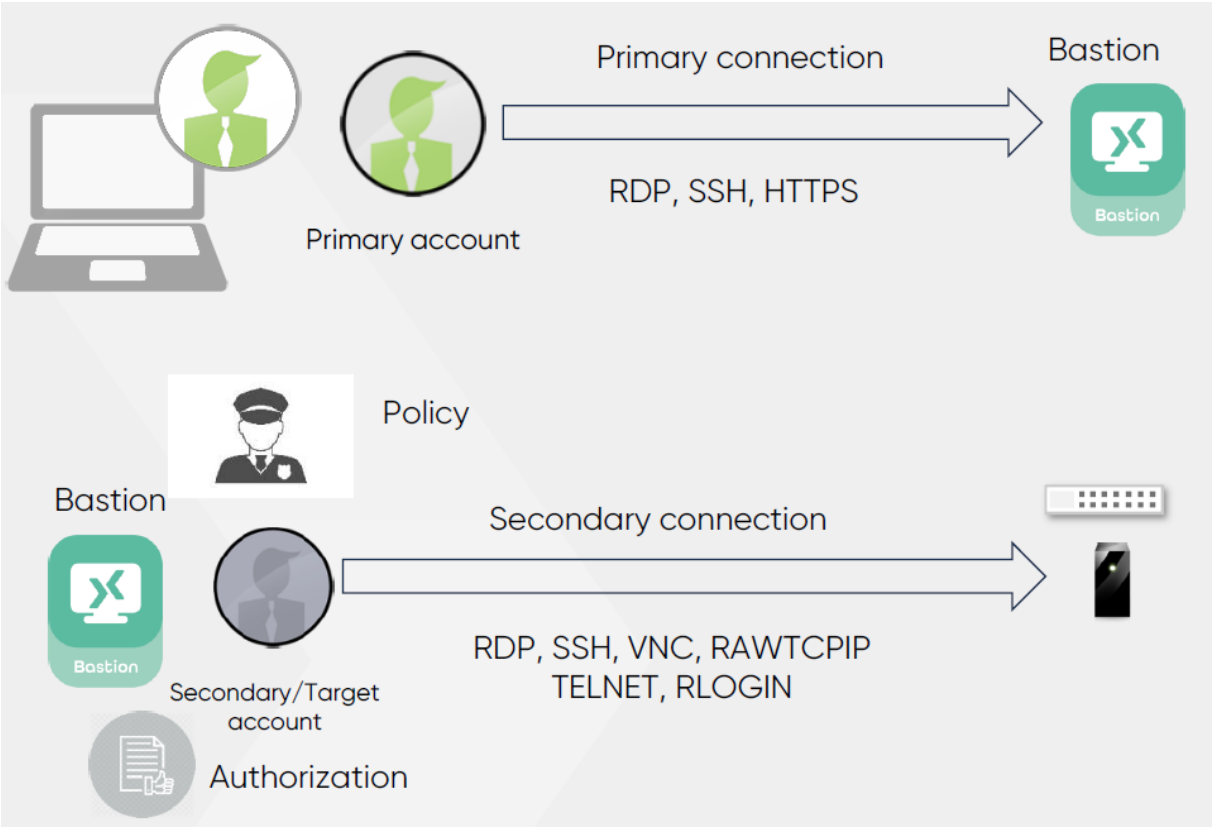
Concepts globaux

Rôle de Session Manager

- Surveiller et centraliser le contrôle des sessions des utilisateurs privilégiés
- Protéger, auditer et enregistrer les sessions accessibles par les utilisateurs, les administrateurs et les tiers
- Garantir la conformité et réduire les risques.
- Aide à contrôler l'accès aux systèmes critiques et aux données sensibles,
- Offrir une surveillance des sessions en temps réel.
- Fournit des fonctionnalités de lecture pour une analyse judiciaire détaillée, aidant les organisations à réagir rapidement aux incidents de sécurité.

Accès à une cible par le Bastion

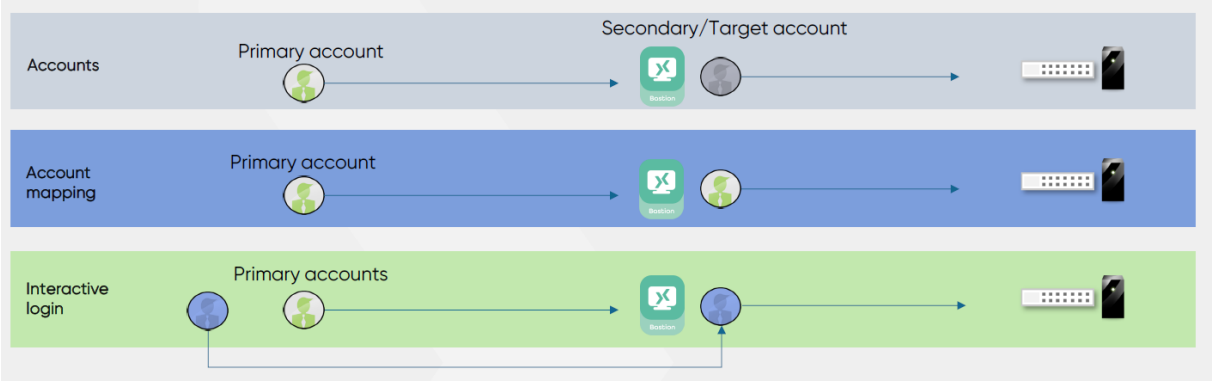
Le Bastion peut gérer à la fois les connexions principales et secondaires.



Il permet :

- de partager l'accès à une application avec plusieurs utilisateurs tout en appliquant le principe du moindre privilège
- de donner accès à une seule application sur RDP,
- de permettre des commandes limitées sur SSH avec le scénario de démarrage.

Le Bastion permet 3 méthodes de connexion secondaires différentes.



Méthode de connexion secondaire Accounts :

- Connexion de l'utilisateur au Bastion avec login/pwd ou SAML ou Kerberos ou certificat X.509, etc.
- Après authentification par le Bastion, celui-ci utilise les identifiants pour établir la connexion vers la cible.
- Compte cible = compte de l'utilisateur (AD recommandé).
- => Système transparent : l'utilisateur utilise son propre compte avec le même mot de passe (si login/pwd) sur la cible finale.
- **Cas d'usage typique** : Environnements où l'utilisateur dispose d'un compte personnel sur la cible

Méthode de connexion secondaire Account mapping (mappage de compte cible) :

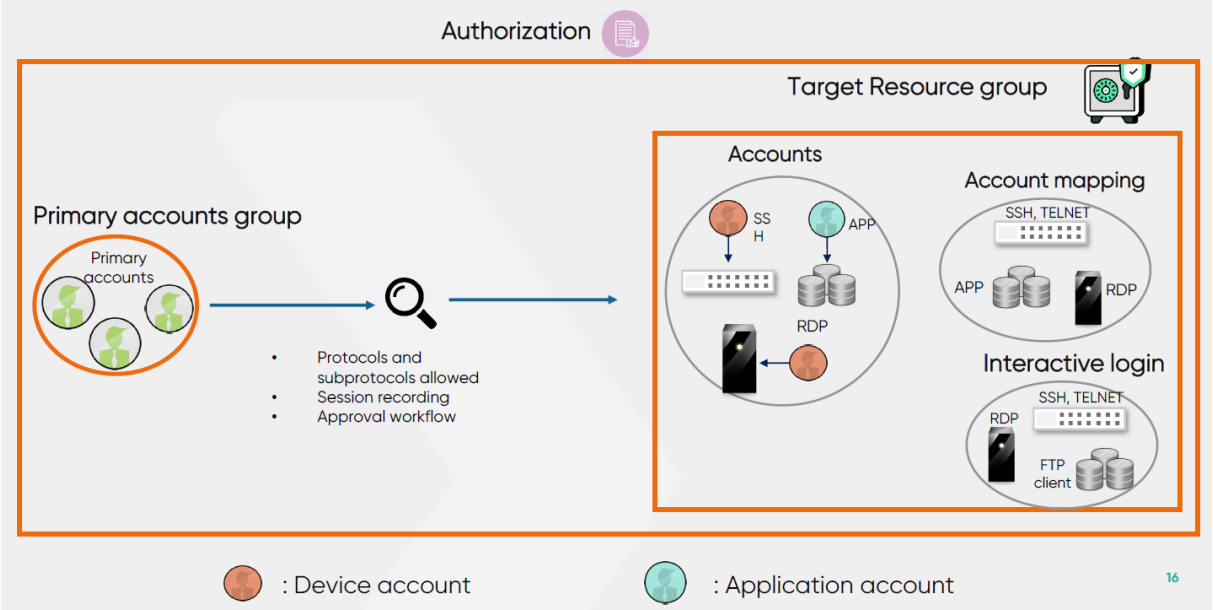
- Connexion de l'utilisateur au Bastion avec obligatoirement login et pwd
- Le Bastion a les identifiants et mots de passe du compte de la cible stockés en interne.
- Pour que l'utilisateur puisse accéder à la cible, le Bastion remplace automatiquement les identifiants et mots de passe primaires de l'utilisateur par ceux du compte cible associé.
- Compte cible ≠ compte de l'utilisateur

- L'utilisateur déclenche la session mais sous un compte cible spécifique.
- Cas d'usage :
  - Comptes partagés/techniques,
  - Accès privilégiés centralisés,
  - Cloisonnement et traçabilité accrues

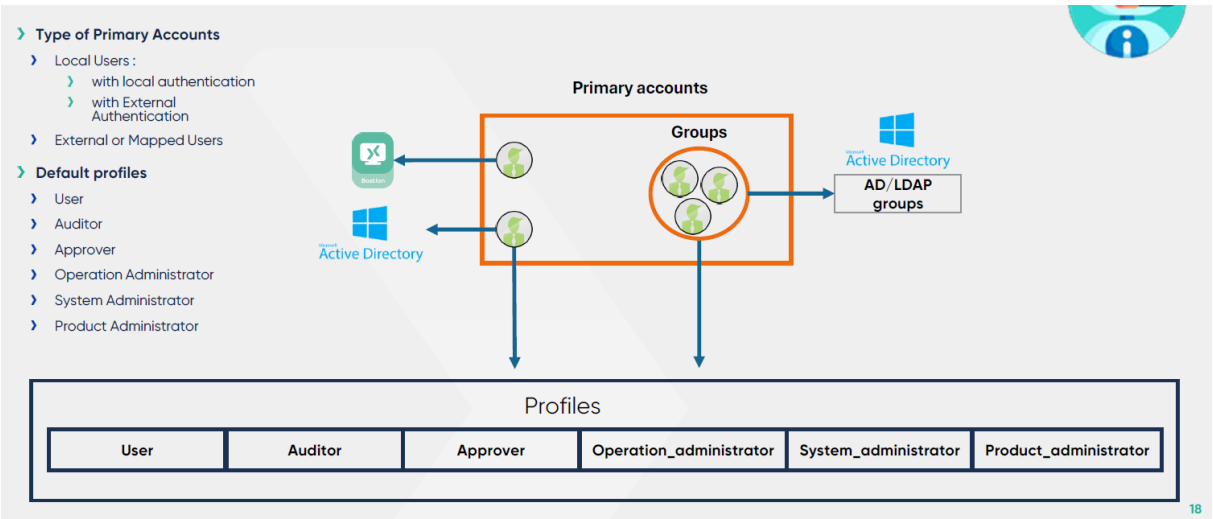
La gestion est simplifiée en appliquant efficacement des règles uniformes grâce à la création de groupes de comptes principaux (Primary Account Groups) et de groupes de ressources cibles (Target Resource Groups).

Les groupes de comptes principaux (Primary Account Groups) sont créés plutôt que des utilisateurs individuels afin de rationaliser la gestion des accès, renforcer la sécurité et simplifier les processus.

De même la création de groupes cibles est essentielle pour une gestion efficace, sécurisée et évolutive des ressources (par exemple, serveurs, applications ou appareils) auxquelles les utilisateurs doivent avoir accès.

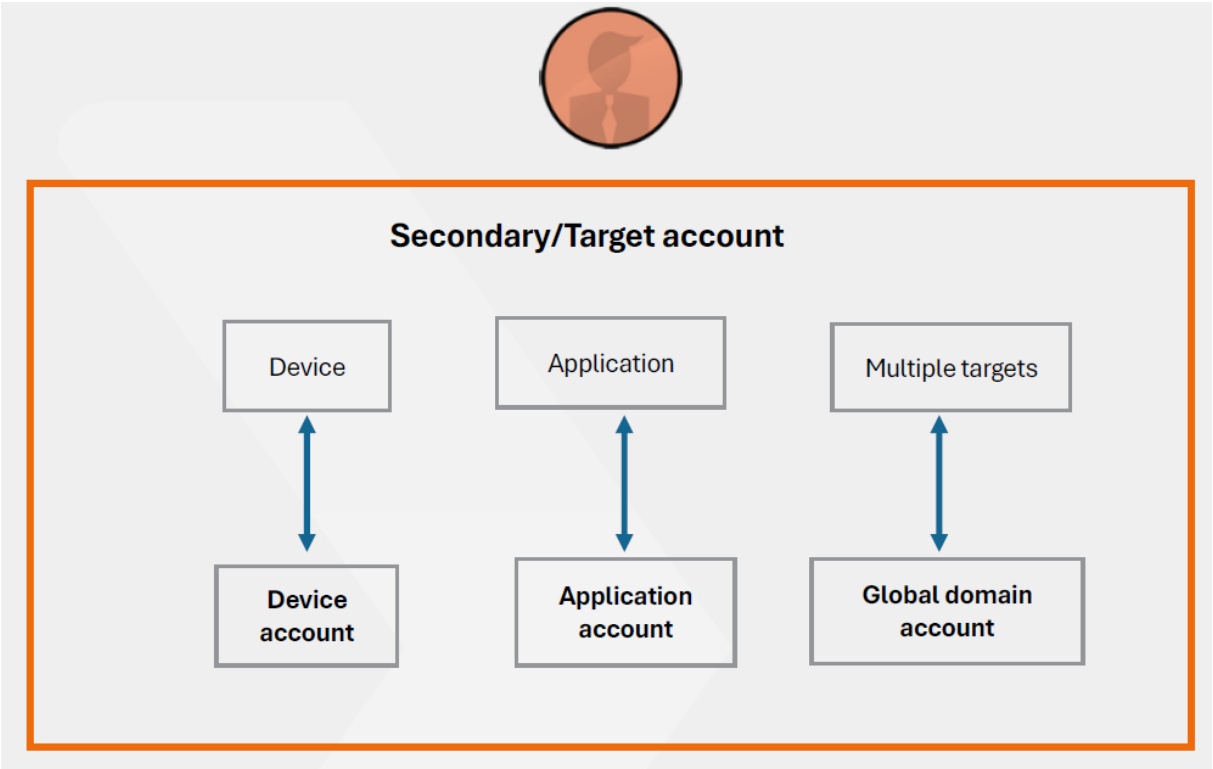


Le Bastion propose des profils par défaut pour simplifier les permissions, en s'adaptant aux besoins organisationnels courants, tout en permettant une personnalisation.



Il est important de bien comprendre les différences entre :

- les comptes d'appareil (Device Accounts),
- les comptes d'application (Application Accounts),
- et les comptes de domaine global (Global Domain Accounts) en tant que comptes secondaires.



Device Accounts :

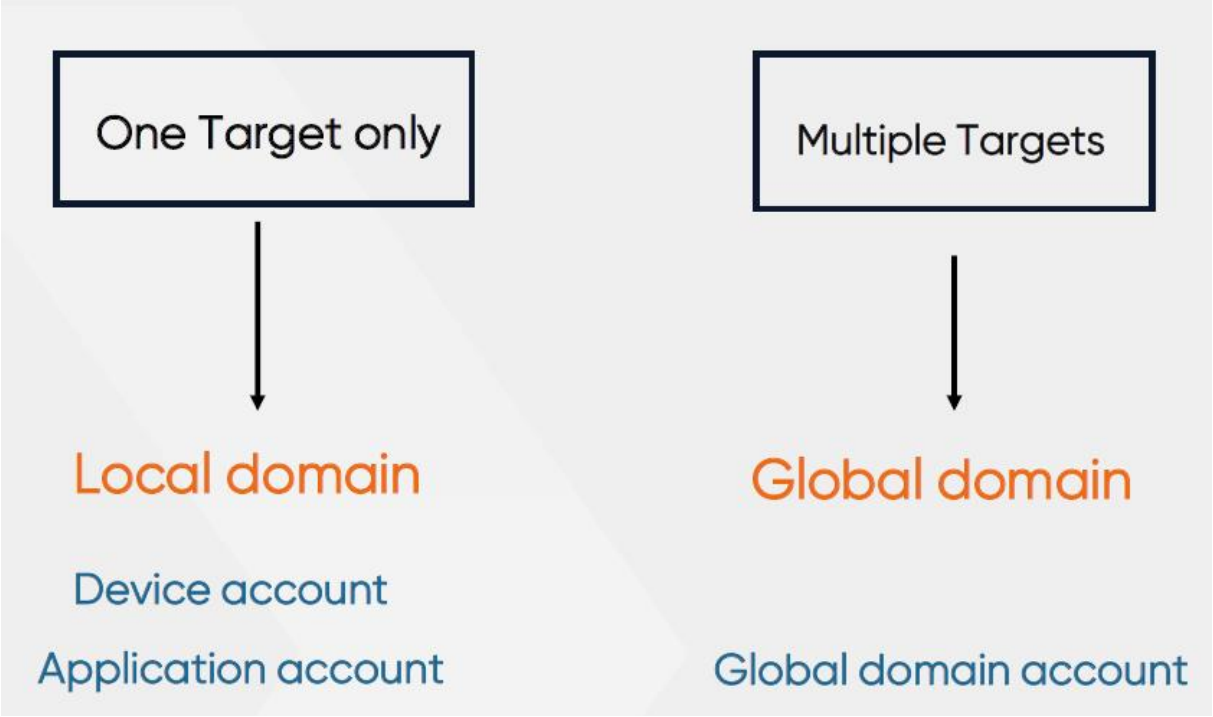
- Accès administratif sur des équipements réseau (parefeu, switchs, routeurs)
- Le compte secondaire à utiliser pour gérer l'équipement est alors un compte de dispositif (Device account)

Application Accounts :

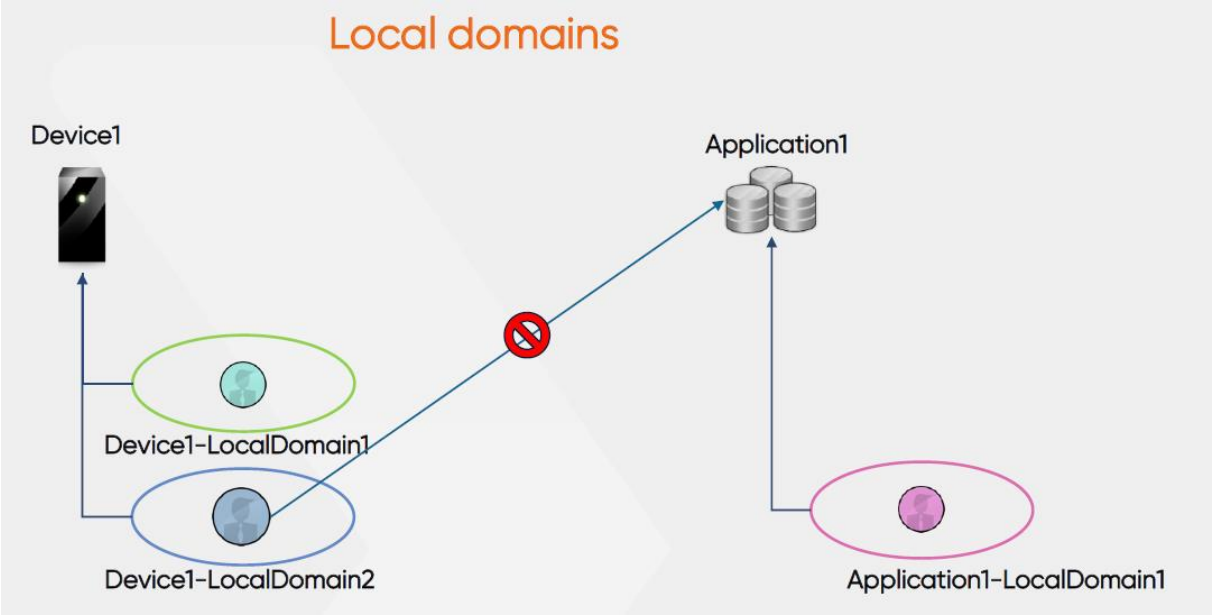
- Accès à une application ou un service spécifique avec des identifiants dédiés
- Le compte secondaire à utiliser est spécifique à l'application ou au service et est alors un compte d'application (Application account)

Global accounts :

- accéder à des ressources partagées, authentifié via un annuaire de domaine
- Les comptes de domaine globaux permettent une authentification et une gestion centralisées, mais ils doivent être gérés de manière sécurisée via le Bastion afin d'éviter tout mouvement latéral non autorisé sur le réseau.



Comment fonctionne un domaine local

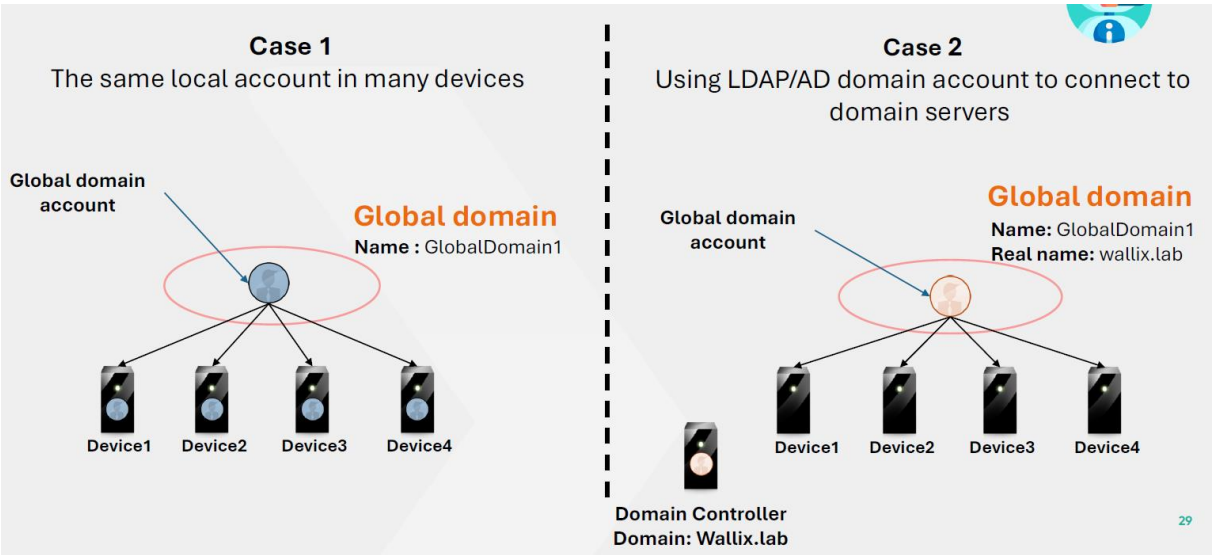


Exemple :

Gestion de plusieurs serveurs Linux (Device1, Device2, Device3 et Device4) hébergeants différentes applications. Ils partagent le même compte secondaire avec le même mot de passe à des fins de maintenance :

- Un compte secondaire partagés sur ces différentes cibles permet aux administrateurs d'utiliser le même compte (root) pour se connecter aux cibles désignées via le Bastion.

Cas d'usage d'un domaine global

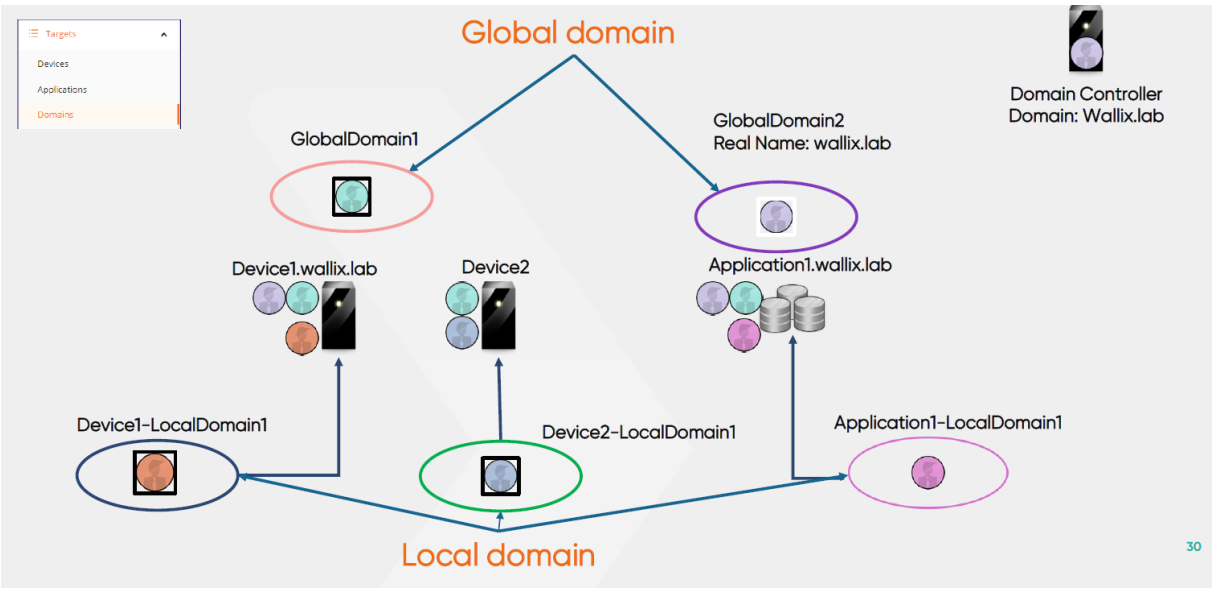


Exemple :

Intégration dans le Bastion d'un contrôleur de domaine gérant les comptes utilisateurs et l'authentification centralisée :

- Configurer et utiliser un domaine global dans WALLIX Bastion pour l'intégrer à un contrôleur de domaine, permettant une authentification centralisée pour plusieurs ressources.

Création de domaine local et domaine global



Différence entre domaine local et domaine global

Portée de l’accès :

Domaine local :

- comptes sont liés à une cible spécifique (par ex., appareil, application).
- Utilisé pour les comptes pertinents pour une seule ressource.
- L'accès est isolé à la cible pour laquelle le domaine est créé.

Domaine global :

- Les comptes peuvent être partagés entre plusieurs cibles.
- Peuvent être utilisés pour des comptes centralisés gérés par un contrôleur de domaine (par ex., Active Directory).
- Offre un accès plus large à plusieurs ressources en fonction des autorisations.

Gestion des comptes :

Domaines locaux :

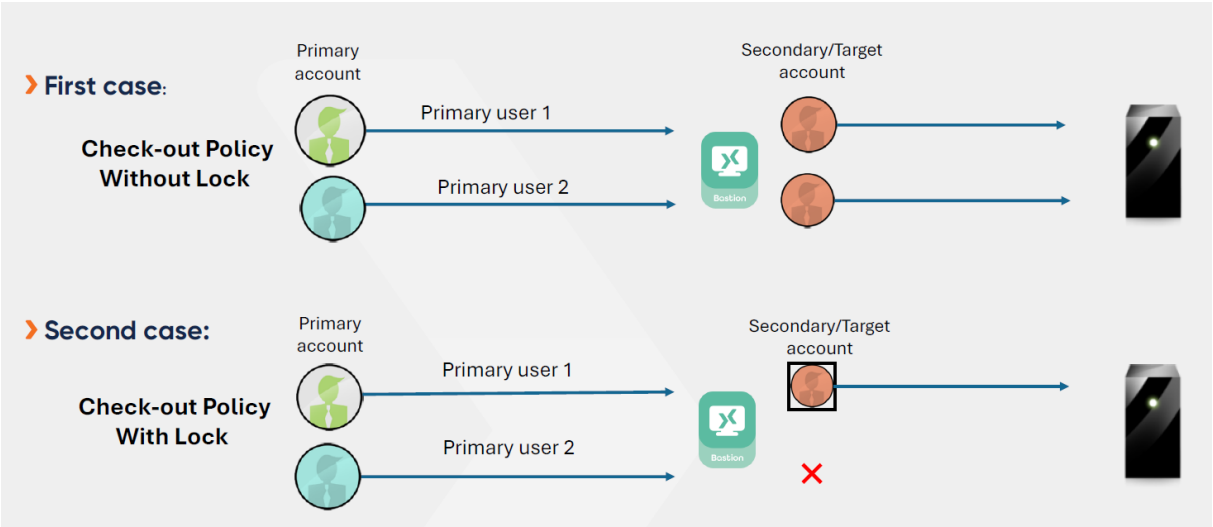
- Création individuelle de compte secondaire pour chaque cible spécifique.
- nécessite une gestion plus détaillée.

Domaines globaux :

- Gestion centralisée des comptes, car ils sont liés à plusieurs cibles ou à un contrôleur de domaine.
- Réduit la duplication et simplifie la configuration des comptes.

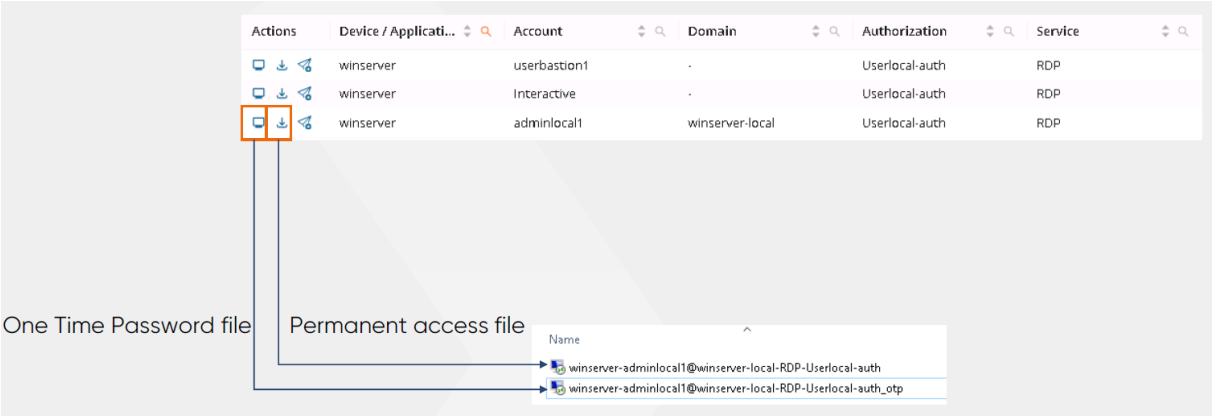
Politique de déverrouillage

Empêcher deux utilisateurs principaux de se connecter en même temps au même objectif avec le même compte cible.

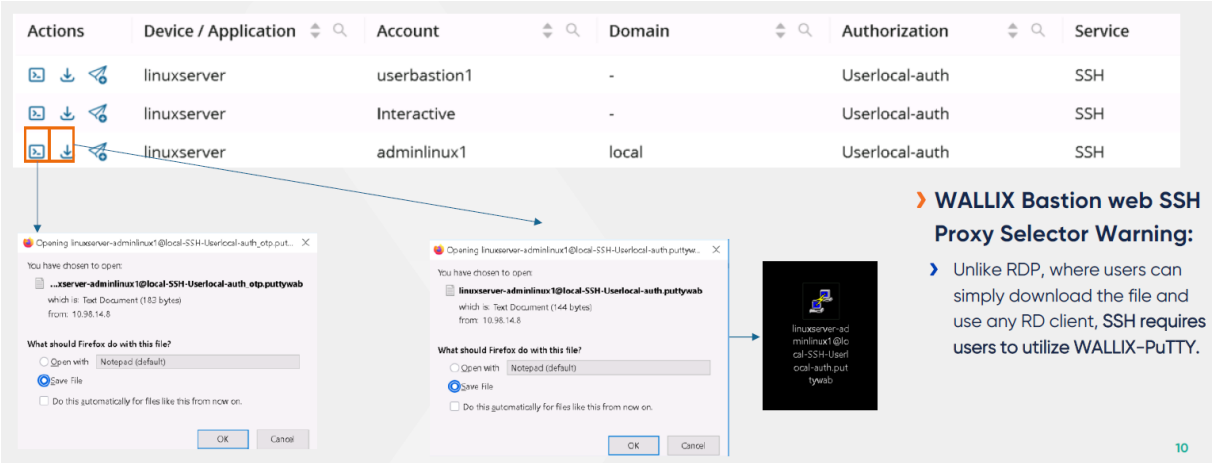


Mode de connexion

Il y a deux types de fichiers de connexion pour les connexions RDP :

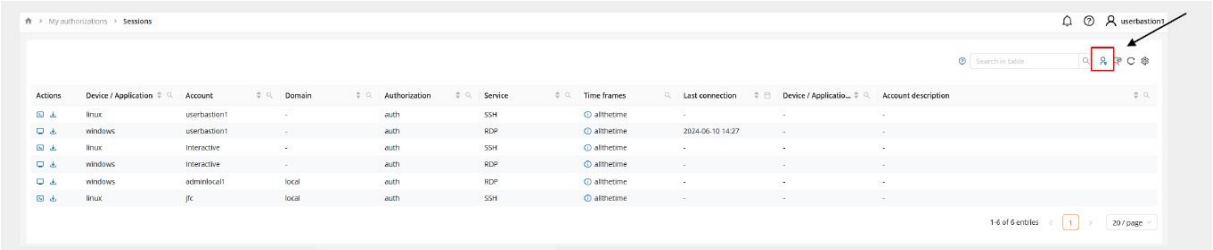


Deux types également pour SSH mais il faut utiliser Wallix-PuTTY

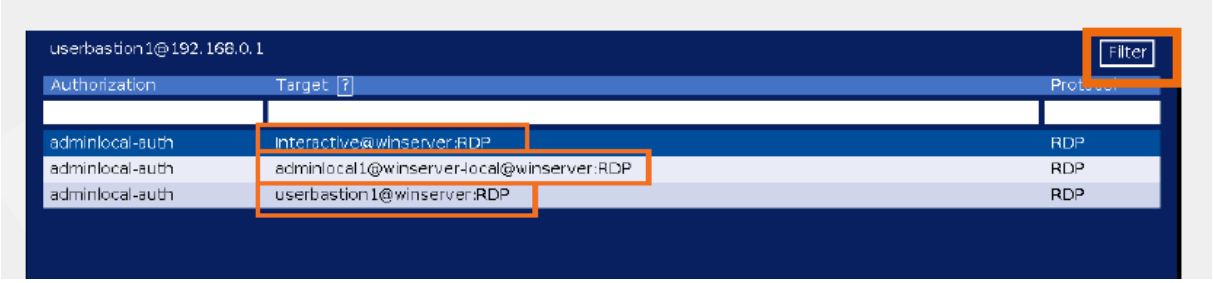


Téléchargement de Wallix-PuTTY

Accessible depuis le menu des options avancées

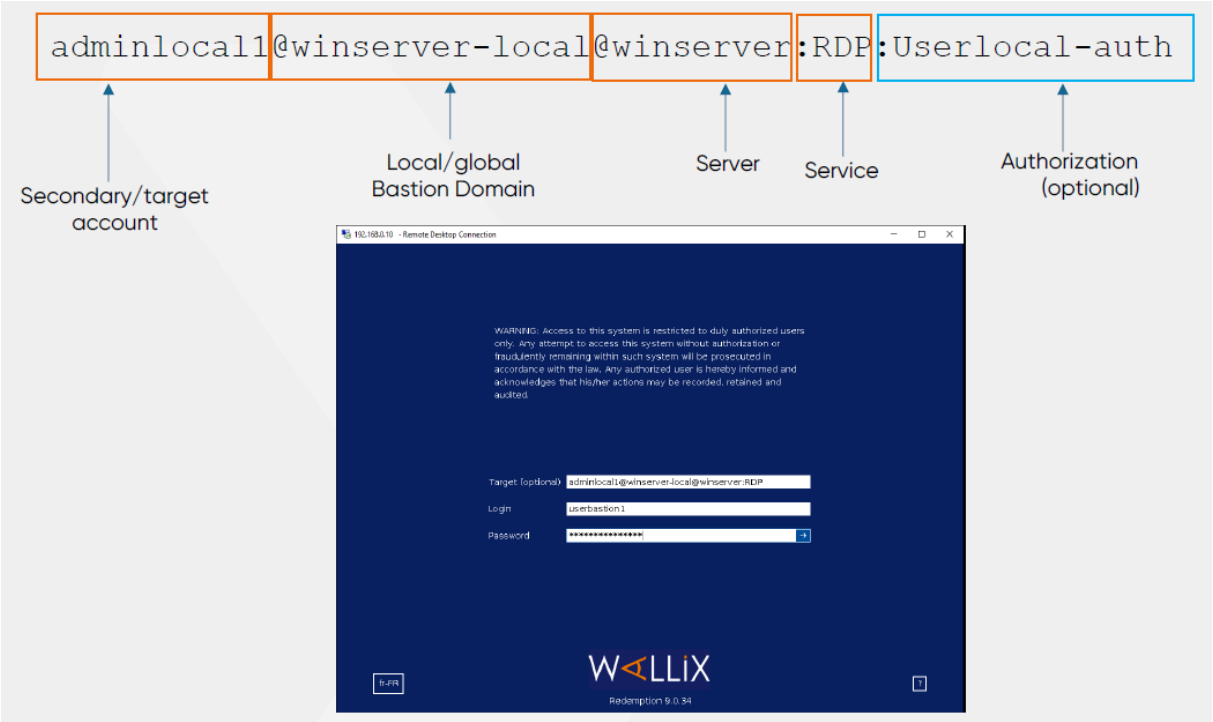


Le sélecteur du proxy RDP

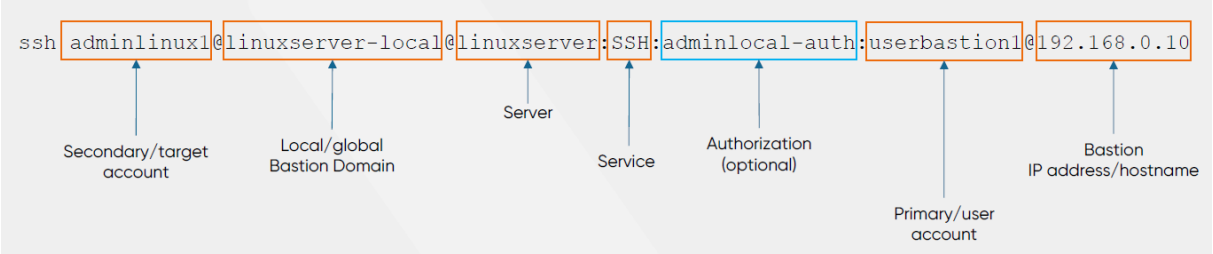


Bypasser le sélecteur pour une connexion RDP

Format à utiliser



Bypasser le sélecteur pour une connexion SSH



Configuration principale du Bastion – LAB 1

Démarche

- Ajouter un utilisateur / compte principal
- Ajouter un groupe d'utilisateurs / compte principal
- Ajouter un appareil cible
- Ajouter un compte secondaire / cible (optionnel)
- Dans un domaine local
- Dans un domaine global
- Ajouter un groupe cible
- Ajouter une autorisation

Création d'un compte principal avec une authentification secondaire locale RDP ou SSH

Créer un utilisateur primaire local :

- Menu **Users** => **Accounts** puis bouton **Add User**
- Renseigner les informations obligatoires : **User name** ; **email**, profil **user**
- Dans le champ **Groups** , sélectionnez le bon groupe s'il existe déjà ;
- Dans le groupes **authentication and backup servers** , sélectionnez **local_password**
- Définissez le **mot de passe** et confirmez-le
- Confirmez la création en cliquant sur le bouton **Apply**.

Créer un groupe d'utilisateur :

- Menu **Users** => **Groups** puis bouton **Add**
- Renseignez le **nom du groupe**
- Sélectionnez les **membres** du groupe
- Confirmez la création en cliquant sur le bouton **Apply**.

Modifier la stratégie par défaut de RDP

- Menu **Session Managment** => **Groups** puis bouton **Add**
- Sélectionnez RDP puis le bouton **Edit this connection policy**
- Activer **NLA NTLM fallback**

Créer les cibles

Pour un serveur Windows accessible en RDP.

Création de la cible

- Menu **Target** => **Device** puis bouton **Add**
- Renseignez le **nom du serveur**, son **adresse IP**
- Confirmez la création en cliquant sur le bouton **Apply**.

Définition du service

- Cliquez sur l'onglet Services puis sur le bouton **Add**
- Sélectionnez **RDP**
- Les informations obligatoires sont pré-renseignées : Service name (RDP) ; Port (3389) ; Connection policy (RDP) ; Proxy options(…)
- Confirmez sur le bouton **Apply and close**.

Pour un serveur Linux accessible en **SSH**.

Création de la cible

- Menu **Target** => **Device** puis bouton **Add**
- Renseignez le **nom du serveur**, son **adresse IP**
- Confirmez la création en cliquant sur le bouton **Apply**.

Définition du service

- Cliquez sur l'onglet Services puis sur le bouton **Add**
- Sélectionnez **SSH**
- Les informations obligatoires sont pré-renseignées : Service name (SSH) ; Port (22) ; Connection policy (SSH) ; Proxy options(…)
- Confirmez sur le bouton **Apply and close**.

Créer les comptes cibles locaux pour les cibles

Méthode 1

- Menu **Target** => **Device accounts** puis bouton **Add**
- Sélectionnez dans le champ **Device** une cible existante
- Renseignez dans les champs **Account name et Account login**, le nom du compte existant dans la cible choisie (login)
- Confirmez la création du compte cible en cliquant sur le bouton **Apply**.
- Cliquez sur l'onglet **Password**, renseigner le pwd du compte de la cible puis cliquez sur le bouton **Apply**

Méthode 2

- Menu **Target** => **Device** ;
- Cliquez sur la cible
- Accédez à l'onglet **Local accounts** puis bouton **Add**
- Renseignez dans les champs **Account name et Account login**, le nom du compte existant dans la cible choisie (login)
- Confirmez la création du compte cible en cliquant sur le bouton **Apply**.
- Cliquez sur l'onglet **Password**, renseigner le pwd du compte de la cible puis cliquez sur le bouton **Apply and close**

Créer un domaine global

- Menu **Target** => **Domains** puis bouton **Add a global domain**
- Renseignez le **nom** éventuellement le **Realm name**
- Confirmez sur le bouton **Apply**

Créer un compte global

Méthode 1

- Menu **Target** => **Domains**

- Choisissez le domaine global
- Cliquez sur **Add an account**
- Renseignez le **nom**, le **login** si différent ainsi que le **mot de passe**
- Confirmez sur le bouton **Apply**

Méthode 1

- Menu **Target** => **Global accounts**
- Cliquez sur le bouton **Add**
- Choisissez le domaine global existant
- Renseignez le **nom**, le **login** si différent ainsi que le **mot de passe**
- Cliquez sur le bouton **Apply**
- Cliquez sur l'onglet **Password**, renseigner le pwd du compte global puis cliquez sur le bouton **Apply and close**

Créer un groupe cible

- Menu **Target** => **Groups** puis cliquez sur le bouton **Add**
- Renseigner le **nom** du nouveau groupe puis cliquer sur **Apply**

Ajout d'une méthode d'authentification au groupe cible

- Menu **Target** => **Groups**
- Sélectionnez le groupe global
- Cliquez sur l'onglet **Session management targets**,
- Sélectionnez la méthode d'authentification voulu (Account) parmi les quatre proposées (Account ; Scenario account, Account mapping et Interactive login)
- Cliquez sur le bouton **Add**
- Pour le champ **From**: sélectionnez **a device and related local accounts**
- Pour le champ **Device** : sélectionnez la **cible** voulue, exemple winserver
- Pour le champ **Service** : sélectionnez **RDP**
- Cochez le **compte local** voulu

Actions à répéter pour d'autres cibles et/ou d'autres méthodes d'authentification.

Pour les méthodes Account mapping et Interactive login, il n'est pas nécessaire de sélectionner un compte local

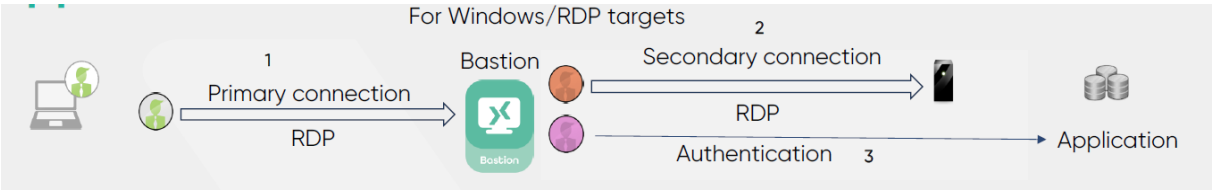
Définir une autorisation

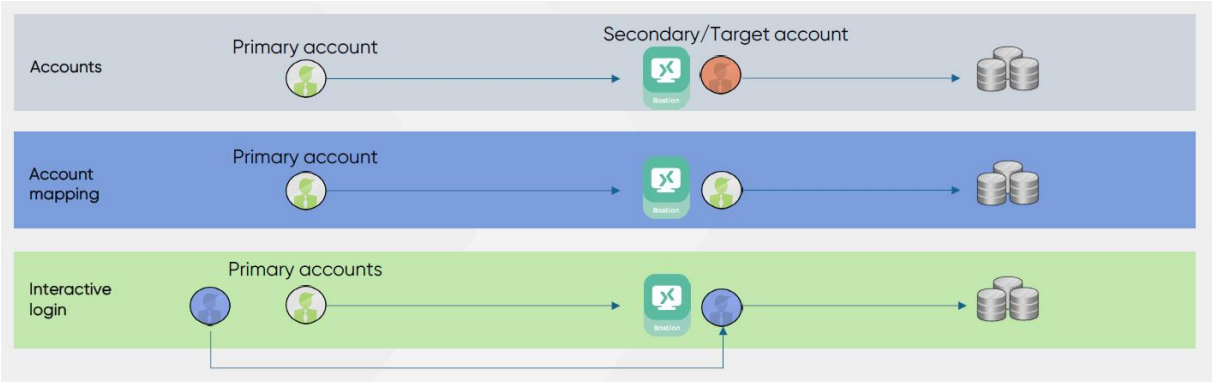
- Menu **Authorizations** => **Manage authorizartions** puis bouton **Add**
- Définir :
  - le nom de l'autorisation
  - le nom du groupe d'utilisateurs
  - le nom du groupe cible
  - le mode d'autorisation : Sessions and secrets
  - les protocoles autorisés : RDP, SSH

- Check the critical target and enable session recording
- Confirmez en cliquant sur le bouton **Apply**

Accéder directement à une application en RDP

- Prérequis pour l'application
- Utilisation des méthodes d'authentification secondaires





3 principales méthodes d'authentification secondaire

Impact sur la connexion à l'application :

Pour la méthode Account :

- Demande la création de comptes de domaine locaux pour se connecter à l'application.
- Création similaire aux comptes d'appareil et sont appelés comptes d'application.
- Alternativement, utilisation des comptes de domaine globaux pour vous authentifier auprès de l'application.

Account mapping :

- Réutilisation par l'application des informations d'identification du compte principal de la connexion RDP,
- similaire à une connexion à un appareil.

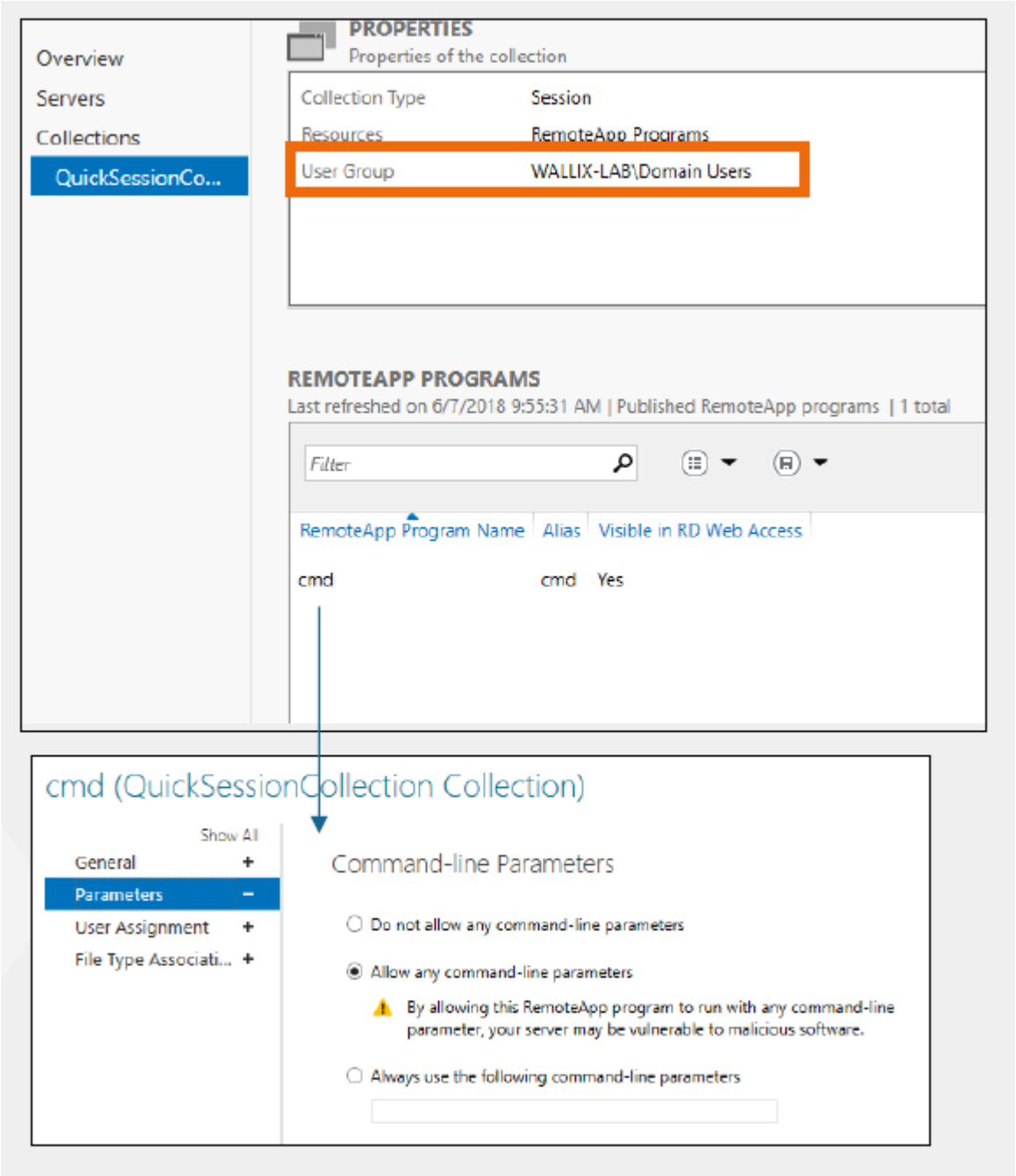
- garantit une authentification fluide de l'application sans que les utilisateurs aient à saisir des informations d'identification distinctes.

Interactive login :

- 2 cas d'utilisation principaux :
  - Saisie manuelle des identifiants : pour les applications où les utilisateurs doivent saisir manuellement leurs identifiants pour démarrer l'application.
  - Aucune identification requise : pour les applications qui ne nécessitent pas du tout d'identifiants utilisateur, sélectionnez Connexion interactive.

Condition préalable sur le serveur qui héberge l'application :

- Activer RDS (Services Bureau à distance) sur le serveur Windows.
- Permettre à l'utilisateur qui ouvre la session RDP sur le serveur d'accéder à la collection RDP.
- SI Session Probe est activé :
  - Publier uniquement cmd.exe et autoriser tous les paramètres de ligne de commande.
- SINON :
  - Publier l'application dans la collection.



Définition : Session probe est un canal virtuel spécifique mis en place par WALLIX Bastion durant une session RDP/SSH. Il permet de capturer, monitorer, enregistrer les actions effectuées pendant la session, en vue d'une surveillance renforcée, d'un audit exhaustif et d'un contrôle en temps réel.

Il existe deux types d'applications :

- Applications qui ne nécessitent pas de compte
- Applications qui nécessitent un compte.

Créer, configurer et publier une application qui ne requiert pas de comptes utilisateur.

Après configuration, valider l'intégration directement dans l'interface web de WALLIX Bastion.

Une application qui nécessite un compte impose la création d’ un compte. Il y a trois étapes principales pour les applications nécessitant un compte :

- création de l'application,
- configuration du compte,
- et publication de la connexion aux utilisateurs.

Une fois ces étapes terminées, l'étape finale consiste à valider l'intégration dans l'interface web WALLIX Bastion.